

SECCIÓN 2.8



Cómo analizar una situación desde fundamentos de ciberseguridad

Temas de esta sección:

- Cómo ordenar el análisis frente a una alerta
- Qué preguntas debería hacerse el analista SOC
- Cómo integrar los conceptos del módulo
- Cómo evitar conclusiones apresuradas
- Cierre del módulo

2.8 | Orden práctico de análisis SOC



En un SOC real los conceptos no aparecen separados. Cuando llega una alerta, el analista debe integrarlos:

1 Entender el evento ¿Qué ocurrió? ¿Cuándo? ¿Dónde? ¿Qué sistema?	2 Identificar activo y usuario ¿Qué activo está involucrado? ¿Qué usuario participó? ¿Qué privilegios tiene?	3 Revisar el contexto ¿Es actividad esperada? ¿Horario y ubicación son normales? ¿Hay historial?	4 Evaluar información involucrada ¿Qué tipo de información está en riesgo? ¿Cuál es su valor e impacto?
5 Analizar impacto CIA ¿Afecta confidencialidad, integridad o disponibilidad? ¿Potencial o confirmado?	6 Buscar evidencia relacionada ¿Hay IOC o IOA? ¿Actividad previa/posterior? ¿Correlación con otros eventos?	7 Revisar controles y exposición ¿Qué control actuó? ¿Bloqueó o permitió? ¿Exposición y criticidad del activo?	8 Clasificar, documentar y escalar ¿Falso positivo, sospechoso o incidente? Documentar con evidencia y escalar si corresponde.



Alerta recibida:

Alert: Unusual file download

User: finanzas.martin

Action: Download 3.5 GB

Folder: Reportes_Financieros_2025

Time: 01:40 AM

Device: Unknown

MFA: Success

After activity: Upload to external storage

Análisis desde fundamentos:

Activo: Información financiera — alta sensibilidad.

CIA: Posible afectación a la CONFIDENCIALIDAD.

Evidencia: Descarga masiva + dispositivo desconocido + subida a almacenamiento externo.

Amenaza: Posible insider o cuenta comprometida.

Controles: MFA exitoso — no alcanza. DLP no generó bloqueo.

Decisión: Escalar con prioridad por posible exfiltración.

Todos los conceptos del módulo aparecen juntos en una sola alerta. Así trabaja un analista SOC real.



Errores comunes del Analista SOC — Módulo 2



Conocer estos errores es tan importante como aprender los conceptos correctos:

✗ Asumir que acceso exitoso = acceso legítimo

✓ Login exitoso y MFA no confirman que quien usa la cuenta sea quien dice ser.

✗ Tratar una vulnerabilidad como incidente confirmado

✓ La vulnerabilidad es debilidad. El incidente requiere evidencia de explotación.

✗ Depender solo de IOC o solo de reputación

✓ Comportamiento sospechoso (IOA) puede ser más valioso que un indicador conocido.

✗ No considerar el tipo de información involucrada

✓ La misma alerta tiene diferente prioridad si involucra plantillas de marketing o credenciales productivas.

✗ Cerrar una alerta porque la herramienta bloqueó

✓ El bloqueo reduce impacto pero no cierra el análisis. Revisá alcance y campaña.

✗ Usar amenaza, vulnerabilidad, riesgo e impacto como sinónimos

✓ Son cuatro conceptos distintos. Confundirlos genera reportes imprecisos y escalaciones mal argumentadas.

✗ Analizar eventos de forma aislada

✓ Una secuencia correlacionada puede cambiar completamente la interpretación.

✗ Confundir exposición con compromiso

✓ Que algo esté expuesto no significa que ya fue comprometido.